Task 1: Review a sample IAM policy

Consider the following example of an overly broad policy.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "*",
      "Resource": "*"
    }
  ]
}
```

Analysis:
- Action: "*" permits every action covered by the policy.
- Resource: "*" makes the grant apply to all resources for which those actions are supported.
- A user with this policy may be able to create, modify, or delete resources across many AWS services.
- This level of access is unnecessary for a typical application reviewer, delivery agent, or read-only user.

Task 2: Least-privilege policy for a food delivery agent

Policy name: DeliveryAgentOrderStatusUpdate

Assume delivery agents need to update order records but must not delete orders. The following is an illustrative policy for a DynamoDB table with a primary key design compatible with the condition.

```
{
  "Version": "2012-10-17",
```

```
  "Statement": [
    {
      "Sid": "UpdateOrderStatus",
      "Effect": "Allow",
      "Action": "dynamodb:UpdateItem",
      "Resource":
"arn:aws:dynamodb:ap-south-1:123456789012:table/Orders"
    }
  ]
}
```

Task 3: Restrict AppUsers to read-only S3 access

Policy name: UserUploadsReadOnly

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "ListUserUploadsBucket",
      "Effect": "Allow",
      "Action": "s3:ListBucket",
      "Resource": "arn:aws:s3:::user-uploads"
    },
    {
      "Sid": "ReadUserUploadObjects",
      "Effect": "Allow",
      "Action": "s3:GetObject",
      "Resource": "arn:aws:s3:::user-uploads/*"
    }
  ]
}
```

Procedure:

1. Open IAM → User groups → AppUsers.
2. Review the existing policies.
3. Remove the broad full-S3-access policy if it is no longer required and you have verified the impact.
4. Attach UserUploadsReadOnly.
5. Test that listing and downloading are allowed, while uploading and deleting are not permitted by this policy.

Task 4: IAM review checklist for a movie ticket booking app

- ☐ Identify identities: List IAM users, groups, roles, attached policies, and their business purposes.
- ☐ Review permissions: Identify wildcard actions, wildcard resources, administrative privileges, and permissions unrelated to the user's role.
- ☐ Check usage: Review IAM Access Advisor, last-accessed information, and CloudTrail events where available to identify unused or rarely used permissions.
- ☐ Apply least privilege: Replace broad permissions with specific actions and resource ARNs, and remove unnecessary permissions after checking dependencies.
- ☐ Reassess regularly: Schedule periodic reviews, investigate unexpected changes, and verify the revised policies using the IAM Policy Simulator and controlled tests.

Task 5: Two or more security improvements

The sample wildcard policy can be improved in several ways:
1. Restrict actions: Replace "Action": "*" with only the actions needed for the job.
2. Restrict resources: Replace "Resource": "*" with specific resource ARNs wherever the action supports resource-level permissions.
3. Use roles and temporary credentials: Prefer temporary role credentials for workloads rather than long-lived access keys.

4. Enable monitoring: Review CloudTrail activity and configure alerts for suspicious permission changes or unexpected access.